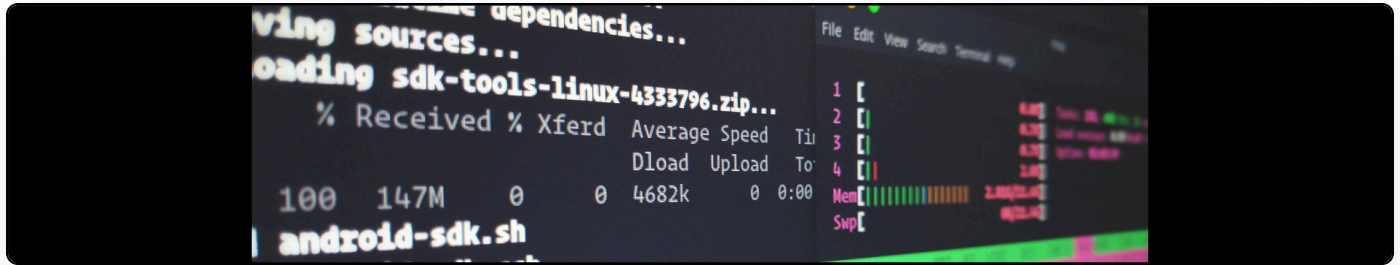


How to block distributed brute-force attacks against Wordpress using fail2ban

Cite as: Martin Paul Eve, "How to block distributed brute-force attacks against Wordpress using fail2ban", *eve.gd: Martin Paul Eve*, August 23, 2015, <https://doi.org/10.59348/yd9ap-s4406>.



In recent days my server has become prey to ever-more brute-force attacks against Wordpress instances. This is a total pain, although they're unlikely (touch wood) to succeed given the complexity of the passwords I tend to deploy and non-standard account names. That said, I got tired of this and wanted to figure out how to block them. The biggest problem I encountered is that some of these password-guessing attacks were coming from a botnet. In other words, in each case it was just one IP that attempted a login, then another IP would attempt the next password, then another for the next etc. This means that we can't rely on the usual approach: watch for X number of bad logins from an IP then ban for 12 hours or so.

Anyway, here's what I did to remedy this situation:

Install the Sucuri Security plugin for Wordpress to verify what the attack looks like. Usually it's a distributed brute-force on the "admin", "administrator" and "domainname" (minus extension: e.g. martineve.com -> user "martineve").

Install fail2ban on your server (apt-get install fail2ban).

Place the following in /etc/fail2ban/filter.d/wordpress.conf:

```

# Fail2Ban configuration file
#
# Author: Charles Lecklider
# Modified by: Martin Paul Eve
#

[Definition]

_daemon = wordpress

# Option: failregex
# Notes.: regex to match the password failures messages in the logfile. The
#         host must be matched by a group named "host". The tag "<HOST>" can
#         be used for standard IP/hostname matching and is only an alias for
#         (?:::f{4,6}:)?(?P<host>[\w\-\.\^_]+)
# Values: TEXT
#
failregex = ^.*wordpress.*: Authentication failure for admin from <HOST>
           ^.*wordpress.*: Authentication failure for Admin from <HOST>
           ^.*wordpress.*: Authentication failure for Administrator from <HOST>
           ^.*wordpress.*: Authentication failure for administrator from <HOST>
           ^.*wordpress.*: Authentication failure for martineve from <HOST>

# Option: ignoreregex
# Notes.: regex to ignore. If this regex matches, the line is ignored.
# Values: TEXT
#
ignoreregex =

```

Make sure to add extra lines to the failregex for the users that the attacker is trying.

Next, install the WP-fail2ban plugin in your Wordpress install and activate it.

Make sure that *you* are **not** using the account names specified above: “Admin”, “admin”, “Administrator”, “administrator”, or the domainname entries.

Add the following to /etc/fail2ban/jail.local:

```
[wordpress]
enabled = true
filter = wordpress
logpath = /var/log/auth.log
bantime = -1
action = iptables-multiport[name=NoAuthFailures, port="http,https"]
maxretry = 1
```

Restart fail2ban (service fail2ban restart).

This will now permanently ban any IP address that tries to login to your server using the “Admin”, “admin”, “Administrator”, “administrator”, or the domainname account entries. If you don’t want it to be permanent, change “bantime” to a positive value in seconds.